

Playbook: SavannaPay Approval-Gated Incident Response

ID: PB-SOAR-001

Name: Approval-gated response for correlated candidate incidents

Version: 1.1.0

Purpose: Turn a scored incident into an auditable case, analyst notification, read-only triage and, only with human approval, simulated containment.

Owner: Firdaws Alnuur, SOC automation owner

Safety: every action is a dry run. No real endpoint, identity, email or network system is changed.

Trigger

A candidate incident is produced by the pipeline with a risk_score from 0 to 100.

Inputs

incident_id, risk_score, severity band, entities (users, assets), event_ids, ai_assist summary, planned_actions.

Preconditions

1. All event timestamps normalized to UTC.
2. Enrichment completed (asset criticality, identity privilege, IOC match).
3. The action is in the fixed allowlist: create_case, notify_analyst, collect_endpoint_triage, isolate_endpoint, disable_identity, revoke_oauth_grant.

Entity resolution

Events join one incident when they share the same user or the same asset and the gap to the previous event is 45 minutes or less.

Workflow steps

1. create_case: always. Timeout 5 s. On error: retry once, then log failure and alert analyst.
2. notify_analyst: if score $\geq$ 40. Timeout 10 s. On error: retry once, then escalate to the SOC channel.
3. collect_endpoint_triage: if score $\geq$ 65. Read-only. Timeout 60 s. On error: continue, mark triage_missing.
4. isolate_endpoint: if score $\geq$ 85. Approval required.
5. disable_identity: if score $\geq$ 85. Approval required.
6. revoke_oauth_grant: if score $\geq$ 85 and an oauth_consent event is present. Approval required.

Action policy (v1.1.0)

- isolate_endpoint is planned only when the incident has endpoint-level evidence (malware_signal). Identity-only incidents are never isolated.
- revoke_oauth_grant is planned, approval required, when an oauth_consent event is in the evidence.
- Indicators match only inside their STIX valid_from/valid_until window, judged at event time.

- Blocked or quarantined events and change-approved activity (an approved CHG ticket) do not count as a malware signal.

Branches

score < 40: step 1 only.

40 to 64: steps 1 and 2.

65 to 84: steps 1 to 3, any containment is approval gated.

85 or more: steps 1 to 3, then steps 4 and 5 (and step 6 when an `oauth_consent` event is present) wait for a named human.

Approvals (steps 4, 5 and 6)

Approval type: named human decision, approve or deny, recorded with analyst name.

Approver role: SOC lead.

Expiry: 30 minutes. After expiry the step returns to `awaiting_approval` and is re-requested.

AI role: advisory only. AI output can never approve or execute an action.

Idempotency

Key = SHA-256(playbook_version | incident_id | entity_id | action).

A repeated call with the same key returns `already_completed` and does nothing.

Terminal states

`simulated`, `denied`, `awaiting_approval`, `already_completed`, `failed_logged`.

Rollback and compensating steps

`isolate_endpoint`: release isolation after analyst review (compensating dry-run step).

`disable_identity`: re-enable account after identity verification.

`revoke_oauth_grant`: a revoked grant is not silently restored; after identity verification the user re-consents, or an analyst re-authorises the app (compensating dry-run step).

Each compensating step needs its own approval and audit record.

Evidence to preserve

`incidents.json`, hash-chained audit log, human decision records with analyst name and UTC time, AI analysis output, the original event IDs.